LABORATÓRIO DE DESENVOLVIMENTO DE SOFTWARE

RELATÓRIO DE REVISÃO

Grupo / Projeto	Grupo 08 — Gestão de Clínica Veterinária
Issue / Tarefa	I063 — Implementar autenticação JWT e controlo de acesso por perfil (EP-001, EP-003)
Sprint / Milestone	Sprint 04 / m3
Executor	André Filipe Moreira Mesquita
Revisor	Ivan Cristiano Silva Mendes
Auditor	Gonçalo Dinis Magalhães Teixeira
Artefacto revisto	Autenticação JWT, políticas de autorização e endpoints EP-001 e EP-003 em /src/backend (arquivo final em /projeto/04-artefactos-tecnicos/04.12-backend/m3-v01, na entrega da M3)
Origem no repositório	Branch 20-i063-implementar-autenticacao-jwt-e-controlo-de-acesso-por-perfil; Pull Request #191 (commits 77f37da, ade93f0, e49736c e 4e0842b, mais um merge de develop); integrado em develop por squash como 6d03d78 em 2026-10-26 11:58.
Data da revisão	2026-10-26
Versão do relatório	v01

1. Âmbito e método

Revisão técnica da autenticação JWT e do controlo de acesso por perfil face aos critérios de aceitação e às verificações do Revisor da Issue I063, à Definition of Done do G08, ao contrato de EP-001 e EP-003 da Documentação de API e ao Regulamento da UC v19. Foram lidos AuthService, JwtTokenService, AutenticacaoExtensions e as políticas; a API foi executada a partir de um clone limpo de develop contra uma base com os dados de demonstração da I061 (palavras-passe de teste próprias), com pedidos válidos e de erro.

2. Verificações realizadas

N.º	Verificação	Método e evidência	Resultado
1	Build e testes	dotnet build sem avisos nem erros; testes unitários a passar (incluindo JwtTokenServiceTests e PoliticasAutorizacaoTests); pipeline da PR #191 com sucesso.	Cumpre
2	CA 1 — EP-001 POST /auth/login	Login real com Rececionista: 200 com token e expiraEm 8 h depois. Verificação manual do Executor com 400 (campos em falta e JSON inválido), 401 e 403 registada na PR.	Cumpre
3	CA 2 — EP-003 GET /auth/me	Com o token: 200 com id, nome, e-mail e perfil lido da base. Sem token, com token adulterado ou expirado: 401.	Cumpre
4	CA 3 — hash seguro e não revelação do e-mail	Na base só existe o hash (PasswordHasher v3, «AQAAAAIAAYag…», 84 caracteres). E-mail inexistente e palavra-passe errada devolvem a mesma mensagem «Credenciais inválidas.», com verificação de um hash de referência.	Cumpre
5	CA 4 / verificação 2 — conteúdo e validação do token	Cabeçalho alg = HS256; claims sub, email, role e jti; exp = iat + 8 h. Token com o payload alterado para Administrador e a assinatura original: 401. Token expirado assinado com a chave certa: 401 «O token expirou». Testes unitários cobrem outra chave e alg none.	Cumpre
6	CA 5 — políticas por perfil e de propriedade	PoliticasAutorizacao com os cinco perfis, Funcionario e ClienteProprietario, utilizáveis por atributo; ClienteAutenticadoControllerBase para /me/*. Rececionista em GET /clinica (só Administrador): 403.	Cumpre
7	CA 6 — conta bloqueada	Conta bloqueada com a palavra-passe certa: 403; com a palavra-passe errada: 401, sem revelar o bloqueio.	Cumpre

N.º	Verificação	Método e evidência	Resultado
		O perfil é sempre o da base (validação da sessão em cada pedido).	
8	CA 7 — log sem palavra-passe	Evento 3001 regista o e-mail e o motivo; a palavra-passe não é passada ao logger.	Cumpre
9	CA 8 — 401/403 no formato da I058	OnChallenge e OnForbidden escrevem { code, message, detail }; os 400 da validação automática também.	Cumpre
10	CA 9 — verificação manual do Executor	Tabela de 15 pedidos na descrição da PR #191 e pedidos no ficheiro ClinicaVeterinaria.Api.http.	Cumpre
11	Segredos	Jwt:Key vazia nos appsettings versionados e ausente do histórico; chave validada no arranque (Base64, ≥ 256 bits).	Cumpre
12	Divergências face à Documentação de API v02	Rotas sem o prefixo /api/v1; erros no formato da I058 em vez de Problem Details (exigido pelo CA 8); Modelo de Classes v02 diz que o JwtTokenService «gera e valida» (a validação é do middleware). Registadas pelo Executor na PR.	Registadas (decisão do grupo)
13	Processo — merge e commit do Revisor	O Auditor aprovou a PR às 11:57 e o Revisor fez o merge às 11:58. O Revisor acrescentou à PR o commit 4e0842b (AuthService passa a usar TimeProvider).	Ver 4
14	Prazos	Prazo do Executor (Sprint Backlog S04 v01, m3-s04-sprint-backlog-v01): 2026-10-25 18:00. Entrega efetiva ao Revisor (abertura da PR #191, GitHub): 2026-10-26 02:06 (+8,1 h). Prazo do Revisor para entregar ao Auditor: normalmente 24 h antes do Sprint Review convocado (2026-10-27 11:00), ou seja 2026-10-26 11:00; como a entrega do Executor foi tardia, o Revisor conserva 24 h desde a receção, ou seja até 2026-10-27 02:06 (Reg. UC §11; AI §16). Entrega efetiva do Revisor ao Auditor: o mapa de pontuação S04 v01 (aprovado no Sprint Review do Sprint 04) regista como conclusão da revisão a aprovação da PR #191 (2026-10-26 11:56); a versão v01 deste relatório foi guardada a 2026-10-26 20:34 (data do ficheiro .docx). Ambas as datas estão dentro do prazo ajustado (2026-10-27 02:06).	Executor: com atraso (ver 5). Revisor: sem atraso.

3. Defeitos e melhorias

Defeitos (correção obrigatória): nenhum identificado no conteúdo técnico revisto.

Propostas de melhoria (não obrigatórias, não penalizam o Executor):

Ref.	Descrição	Seguimento
M1	Decidir em grupo o prefixo /api/v1 e o formato de erro (Problem Details ou o da I058), que afetam todos os controladores, e alinhar a Documentação de API.	Issue própria, transversal ao backend.
M2	Corrigir no Modelo de Classes v02 a responsabilidade do JwtTokenService («gera» em vez de «gera e valida»).	PR #169 (Modelo de Classes v02).
M3	O ExceptionHandlingMiddleware (I058) expõe exception.Message nos erros 500.	A Issue #194, onde estava registado, foi eliminada do GitHub; o defeito continua em develop (verificado em 2026-10-29). Abrir uma nova Issue com a etiqueta defeito.

4. Desvios de processo

Registo da PR #191 no GitHub (verificado em 2026-10-30). Commits e autores: 77f37da «feat(auth): adicionar AuthController e login JWT» (autor Ivan Mendes, 2026-10-25 22:48); 68d9706 (merge de develop no ramo i063-work, 23:40), ade93f0 «feat(auth): concluir autenticação JWT e controlo de acesso por perfil» (23:54) e e49736c

«docs(backend): comando de geração da chave JWT…» (2026-10-26 00:55), com autor «Claude», que identifica uma ferramenta de IA e não quem a utilizou; 4e0842b «fix(auth): usar TimeProvider no AuthService…» (autores Ivan Mendes e Claude Opus 5.5, 2026-10-26 10:51). Nenhum commit tem o Executor como autor. A PR foi aberta pelo Executor (2026-10-26 02:06), aprovada pelo Revisor às 11:56 e pelo Auditor às 11:57, e integrada pelo Revisor às 11:58, depois da aprovação do Auditor. O Revisor declara que participou na produção do código que reviu: é autor do commit inicial do ramo (77f37da, AuthController e login) e da correção do TimeProvider (4e0842b). Esta participação é ajuda material e devia ter sido formalizada como transferência, com nomeação de outro Revisor (Reg. UC §12; AI §19). Não foi: a ata do Sprint Review do Sprint 04 regista «Transferência formal: Não aplicável». O Revisor regista-a para que o grupo decida em reunião formal como a regularizar; a falta de transferência impede redistribuir pontos retroativamente (AI §19).

5. Classificação do Executor e conclusão

Categoria de qualidade proposta	Aceite sem correções obrigatórias (Q = 100%), aprovada no Sprint Review do Sprint 04 (ata m3-s04-20261027-sprint-review-ata-v01, secção 6.2). A classificação refere-se à qualidade do resultado entregue; a participação do Revisor na produção do código (secção 4) fica registada para decisão do grupo.
Atraso	Executor: PR #191 aberta em 2026-10-26 02:06 (+8,1 h face ao prazo de 2026-10-25 18:00) e integrada em 2026-10-26 11:58 (+18,0 h). Escalão «mais de 8 e até 24 horas, inclusive»: penalização de 25% (AI §17.1), aprovada no Sprint Review do Sprint 04 (ata m3-s04-20261027-sprint-review-ata-v01, secção 6.5); o escalão é o mesmo quer se conte a abertura da PR quer a integração. A hora confirmada no GitHub é 2026-10-26 02:06:58, 8 h 06 min 58 s depois do prazo: o escalão é o de «mais de 8 e até 24 horas».
Conclusão	Revisão técnica concluída sem defeitos obrigatórios. As divergências face à Documentação de API ficam para decisão do grupo. A tarefa segue para Em Auditoria de Qualidade. Situação posterior: tarefa aprovada e colocada em Done no Sprint Review do Sprint 04 (ata m3-s04-20261027-sprint-review-ata-v01, secção 6.6).

Revisor	Data e hora	Assinatura digital
Ivan Cristiano Silva Mendes	Data e hora conforme a assinatura digital	Assinado por: **IVAN CRISTIANO SILVA MENDES** Num. de Identificação: 15482845 Data: 2026.10.30 21:40:41+00'00'